CYBERSECURITY • HANDS-ON PROJECT

Phishing Simulation & Social Engineering Assessment

Kali Linux • Zphisher • Social-Engineer Toolkit (SET)

AUTHOR	DATE
Naveen Kumar S	18/10/2026
TOOLS	PORTFOLIO
Zphisher • Social-Engineer Toolkit (SET)	LinkedIn • GitHub

Project focus
A controlled cybersecurity exercise exploring how phishing pages and social-engineering workflows can be used to manipulate users, expose credentials, and create opportunities for further account compromise. The project is documented for educational and authorized security-testing purposes.

01 • Project Overview

This project examines two closely related attack surfaces: phishing websites and email-based social engineering. Using Kali Linux, I explored Zphisher first to understand how an attacker can present a familiar-looking login experience, followed by the Social-Engineer Toolkit (SET) to study how deceptive email campaigns can be structured.

The exercise demonstrates an important security principle: a technically secure service can still be exposed when a user is convinced to trust the wrong website or message. The technical tooling therefore needs to be understood together with the human behavior it attempts to influence.

02 • Objectives

- Understand the structure of a phishing-page workflow and the security risks created by website impersonation.
- Examine how familiar branding and login interfaces can be used to create false trust.
- Explore the email-based social-engineering workflow provided by SET.
- Understand how exposed email information can increase the impact of a successful phishing incident.
- Translate the observed attack concepts into practical defensive controls.

03 • Tools Used

TOOL	PURPOSE IN THIS PROJECT
Zphisher	Explored phishing-page templates and the workflow used to simulate a convincing login page in a controlled environment.
Social-Engineer Toolkit (SET)	Explored social-engineering menus and the email-related workflow used to model phishing communication scenarios.
Kali Linux	Provided the security-testing environment in which both tools were executed and observed.

04 • Zphisher — Phishing Simulation

The first part of the project focused on Zphisher. The tool provides a collection of phishing-page templates designed to demonstrate how attackers can imitate well-known online services. In a controlled lab, this makes it possible to study the visual and behavioral techniques that can make a fraudulent page appear legitimate.

The security lesson is not the brand being imitated; it is the trust mechanism. Users often recognize a familiar logo, page layout, or login form before they verify the actual domain. That gap between visual recognition and URL verification is a major phishing risk.

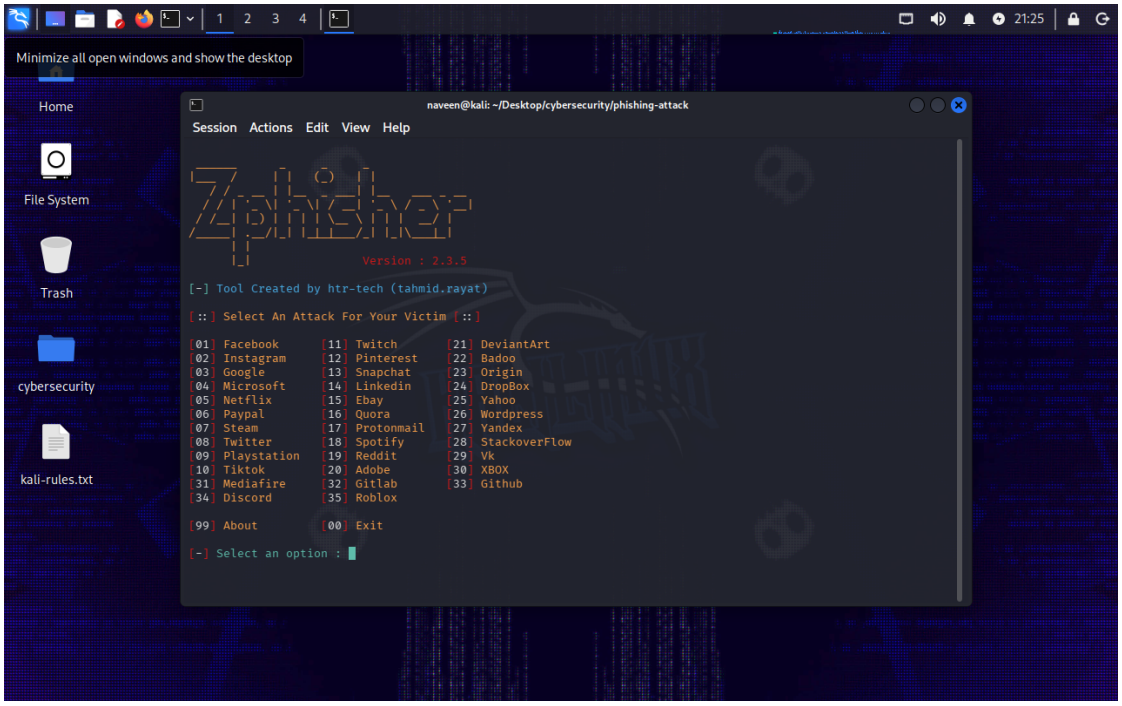


Figure 1 — Zphisher template selection. The interface illustrates the range of simulated service templates available for a phishing-awareness exercise. The key risk is that a familiar visual interface can make a fraudulent destination appear trustworthy.

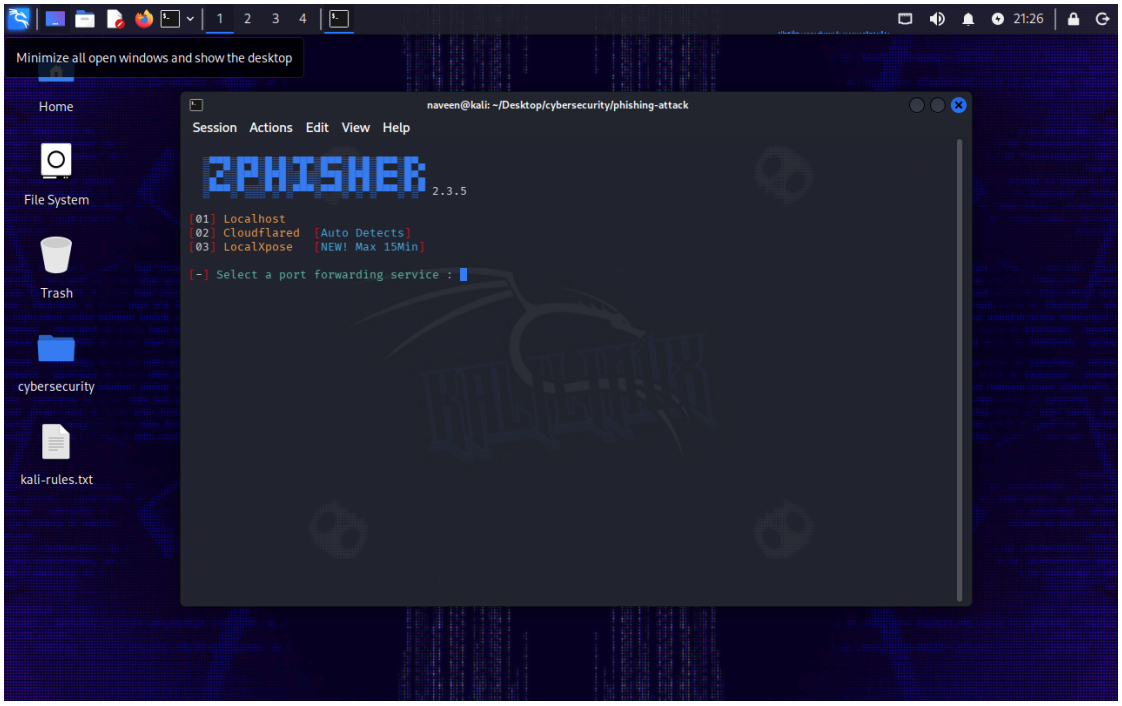


Figure 2 — Zphisher access and tunneling options. This screen shows the networking choices presented by the tool for exposing a test page. From a defensive perspective, it reinforces why users should verify the destination domain rather than relying on the appearance of a page.

What this demonstrates

- Phishing can begin with simple impersonation rather than exploitation of a software vulnerability.
- A realistic login page can reduce a user's suspicion if the domain is not checked.
- The safest test environment uses synthetic credentials and an explicitly authorized target.

05 • Social-Engineer Toolkit (SET)

The second part of the project focused on the Social-Engineer Toolkit. SET provides a structured interface for studying social-engineering scenarios, including email-based workflows. This makes it useful for understanding how an attacker can combine a technical lure with psychological triggers such as urgency, authority, curiosity, or familiarity.

The objective of this stage was to understand the attack workflow, not to target real users. A phishing message becomes more effective when the recipient expects the communication, recognizes the branding, or believes there is a reason to act immediately.

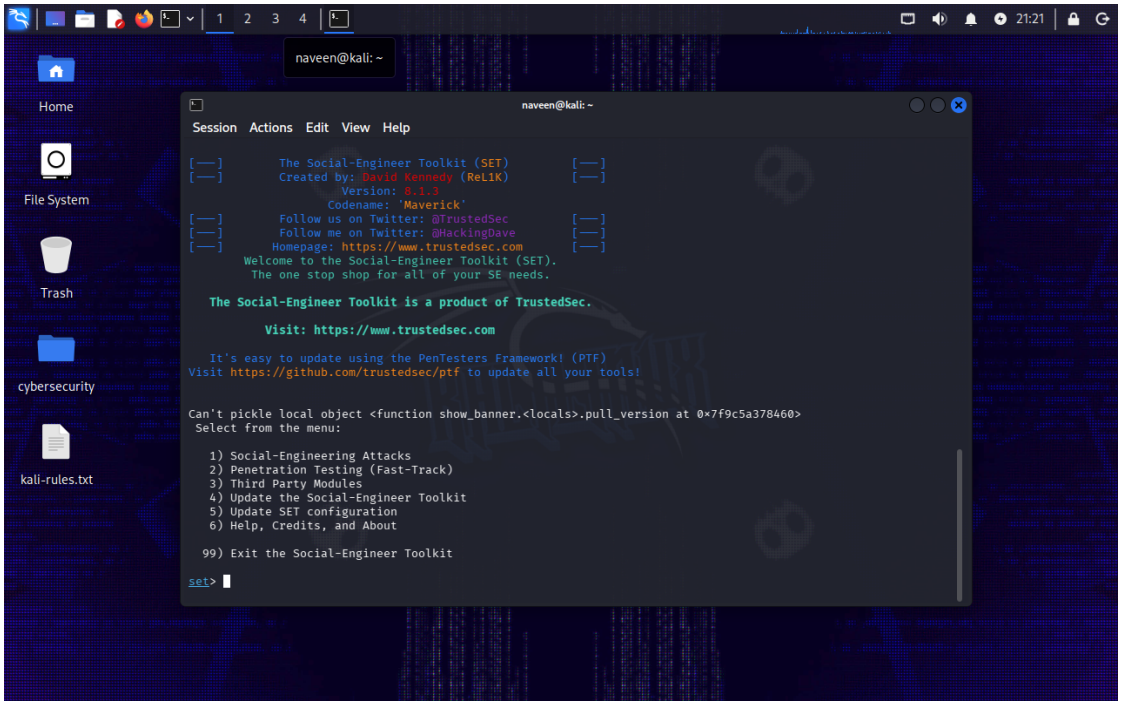


Figure 3 — Social-Engineer Toolkit startup interface. SET provides multiple social-engineering assessment categories. The interface demonstrates how different attack paths can be organized inside one security-testing framework.



Figure 4 — SET email-related workflow. The menu demonstrates how email can be incorporated into a social-engineering scenario. Defenders should treat unexpected requests for credentials, links, payments, or urgent actions as potential indicators of phishing.

What this demonstrates

- Social engineering combines technical delivery with psychological manipulation.
- Email can be used to create a believable context around a malicious or deceptive link.
- A successful defense depends on both technical controls and users who know how to verify suspicious requests.

06 • Security Findings

01 — Visual trust is not identity verification

A familiar interface does not prove that a website is genuine. The browser address and domain must be verified before credentials are entered.

02 — Email context can influence decisions

Attackers can make messages appear credible by using familiar language, branding, urgency, or an apparently legitimate reason for the requested action.

03 — Credential exposure can become a chain of compromise

An exposed account can reveal correspondence, reset links, personal information, and other material that may support additional attacks.

04 — Human and technical controls must work together

Email filtering, MFA, authentication standards, monitoring, and user awareness provide stronger protection when deployed as layers rather than as isolated controls.

07 • Defensive Controls

- Phishing-resistant authentication: Use passkeys or other phishing-resistant MFA where supported.
- Domain verification: Check the complete domain before signing in and do not trust appearance alone.
- Email security: Use SPF, DKIM, and DMARC alongside filtering and threat-detection controls.
- User reporting: Give users a simple process for reporting suspicious messages and websites.
- Account monitoring: Alert on unusual sign-ins, new sessions, password changes, and other high-risk account events.
- Incident response: If credentials are exposed, reset passwords, revoke sessions, review activity, and investigate related access.

08 • Conclusion

This project provided a practical view of how phishing and social engineering can work together. Zphisher demonstrated the importance of recognizing fraudulent login pages and verifying domains, while SET illustrated how email can be used to build a convincing social-engineering scenario.

The central security lesson is simple: trust should be verified, not assumed. Strong authentication, secure email controls, careful URL verification, user awareness, and effective incident response together reduce the likelihood and impact of phishing-based compromise.

Ethical testing & privacy
This project is intended for cybersecurity education and authorized security testing. Practical exercises should use controlled infrastructure, consenting participants, and synthetic credentials. Real credentials, personal information, or live phishing links should not be collected or published without explicit authorization.

NAVEEN KUMAR S
Cybersecurity Project Documentation
LinkedIn
GitHub